

Introduction

This report documents a simulated ransomware attack executed in a controlled laboratory environment.

The purpose of this exercise is to demonstrate the detection, investigation, and response workflow for ransomware activity using Elastic Security.

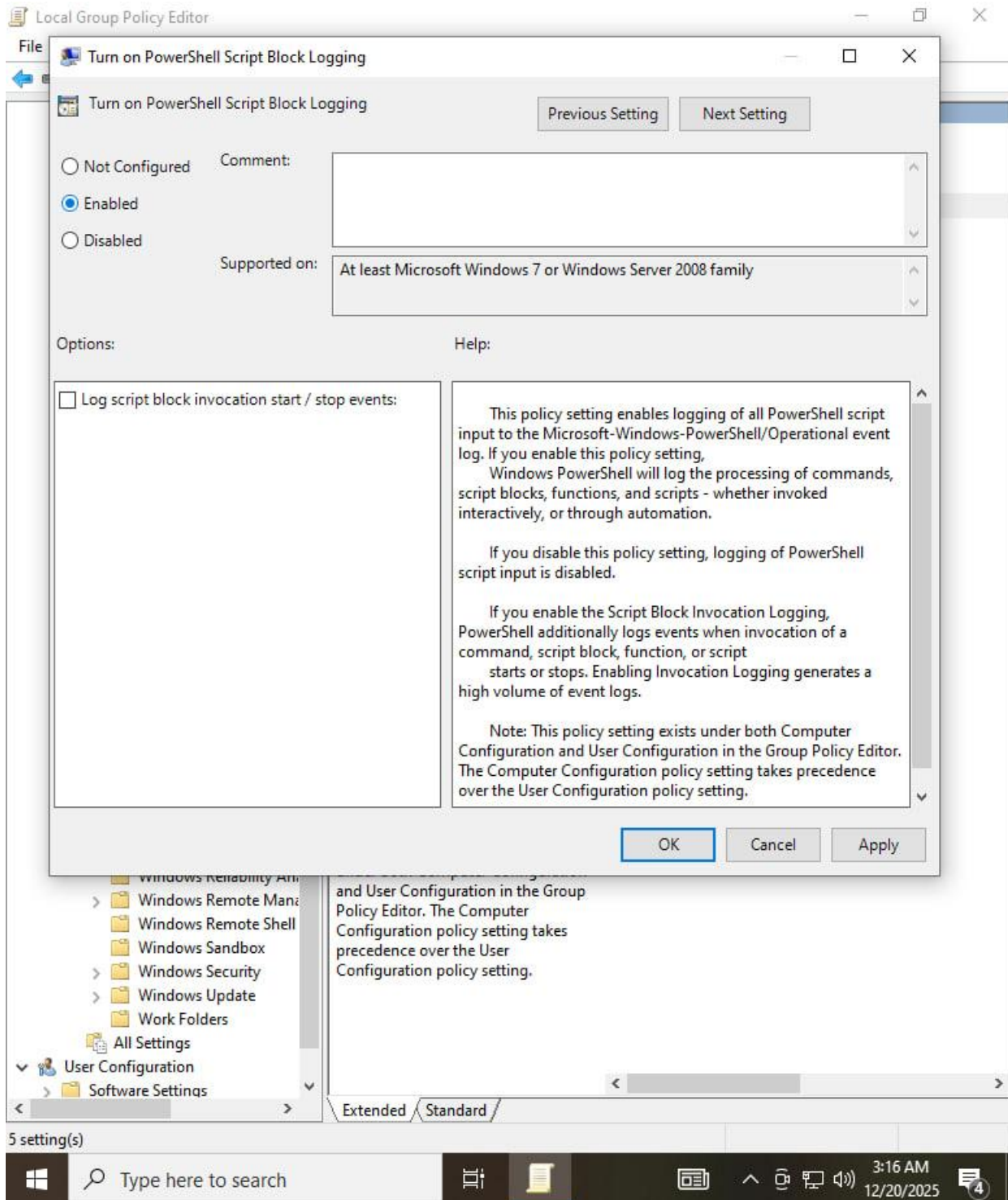
A PowerShell-based ransomware simulation script was executed on a Windows 10 endpoint acting as the victim system.

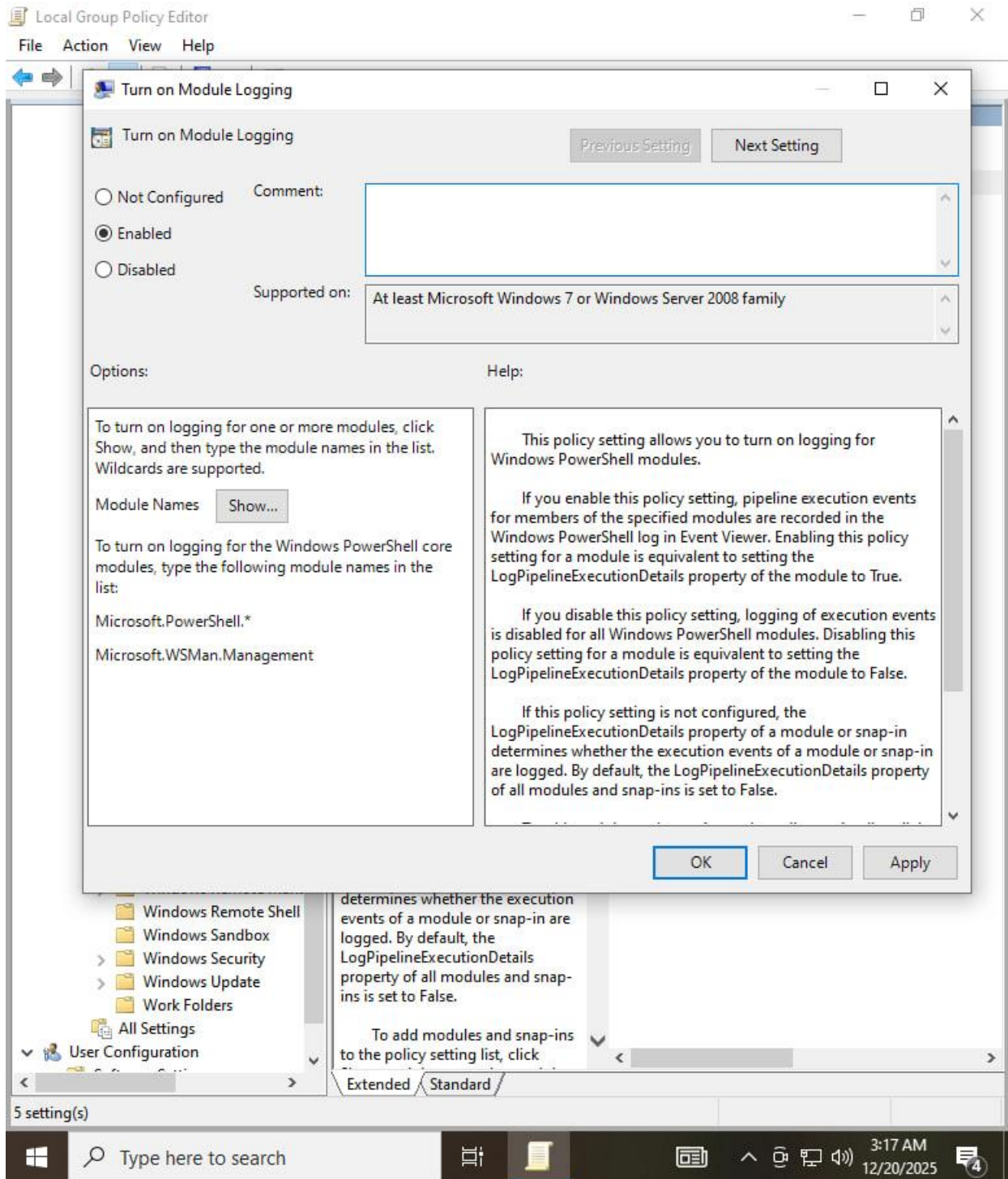
The script leveraged PowerShell commands to modify file contents, rename files to simulate encryption, and create a ransom note.

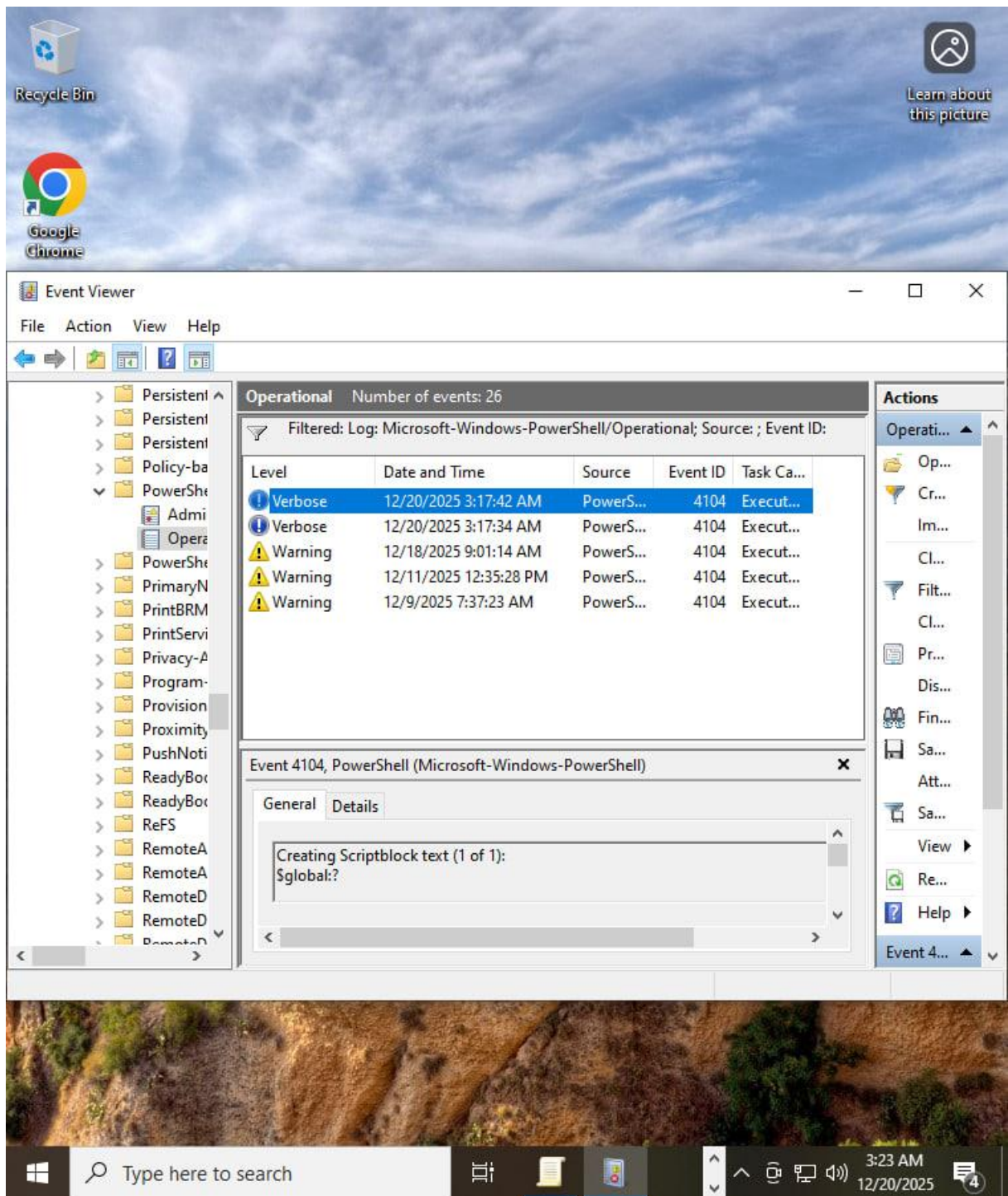
The activity was monitored using native Windows logging, Sysmon telemetry, and Elastic SIEM.

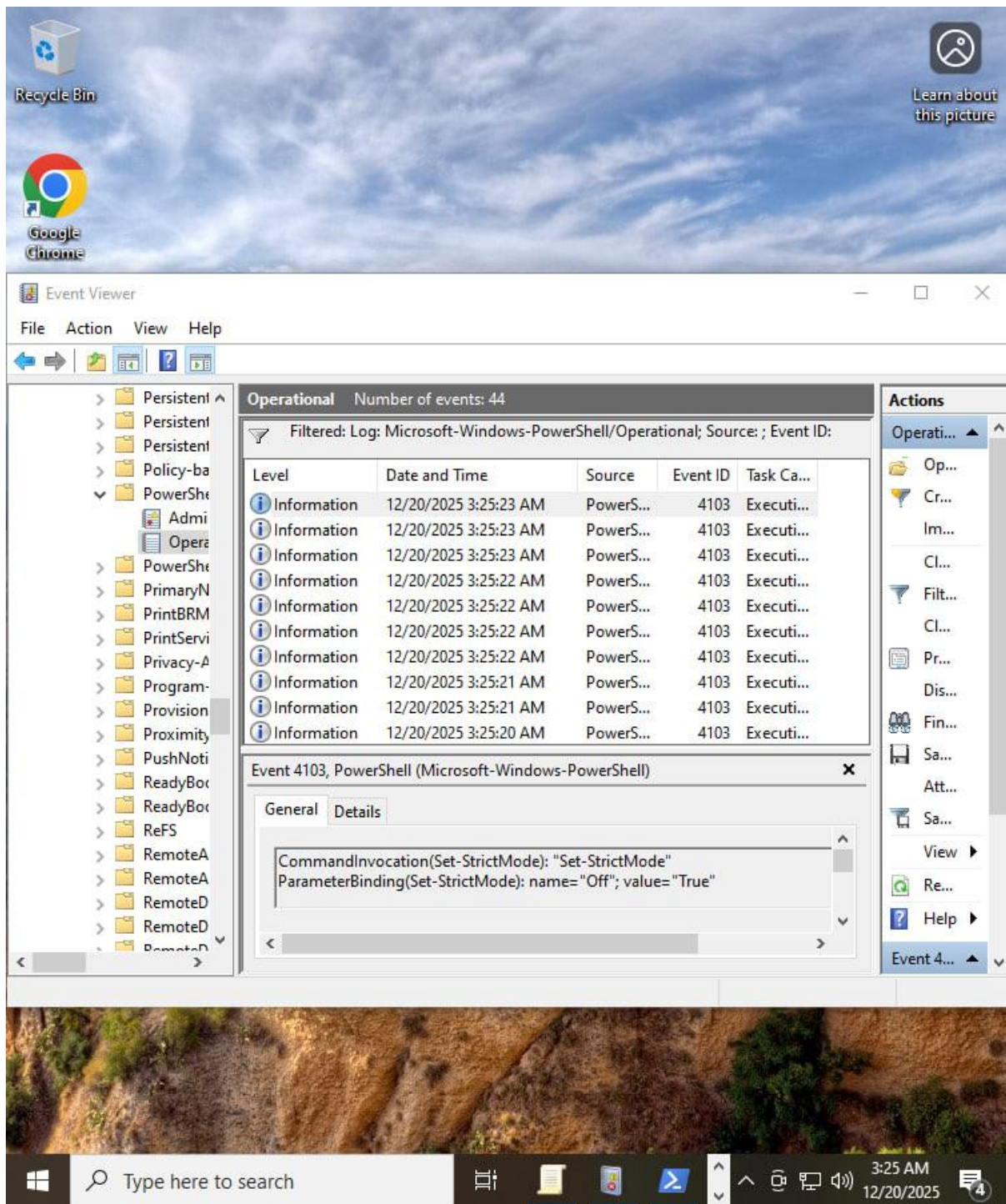
A custom detection rule successfully identified the malicious behavior and generated an alert mapped to **MITRE ATT&CK techniques T1059.001 (PowerShell) and T1486 (Data Encrypted for Impact)**.

Preparing the environment for the lab









Incident Response Playbook

Phase 0: Preparation

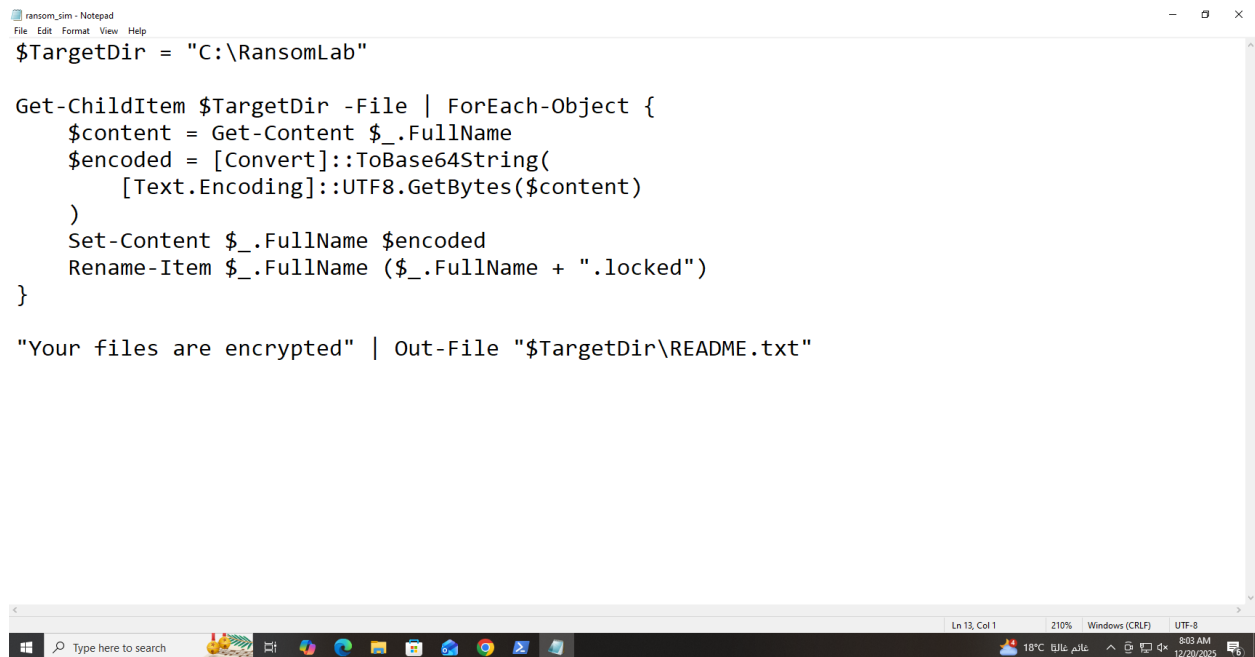
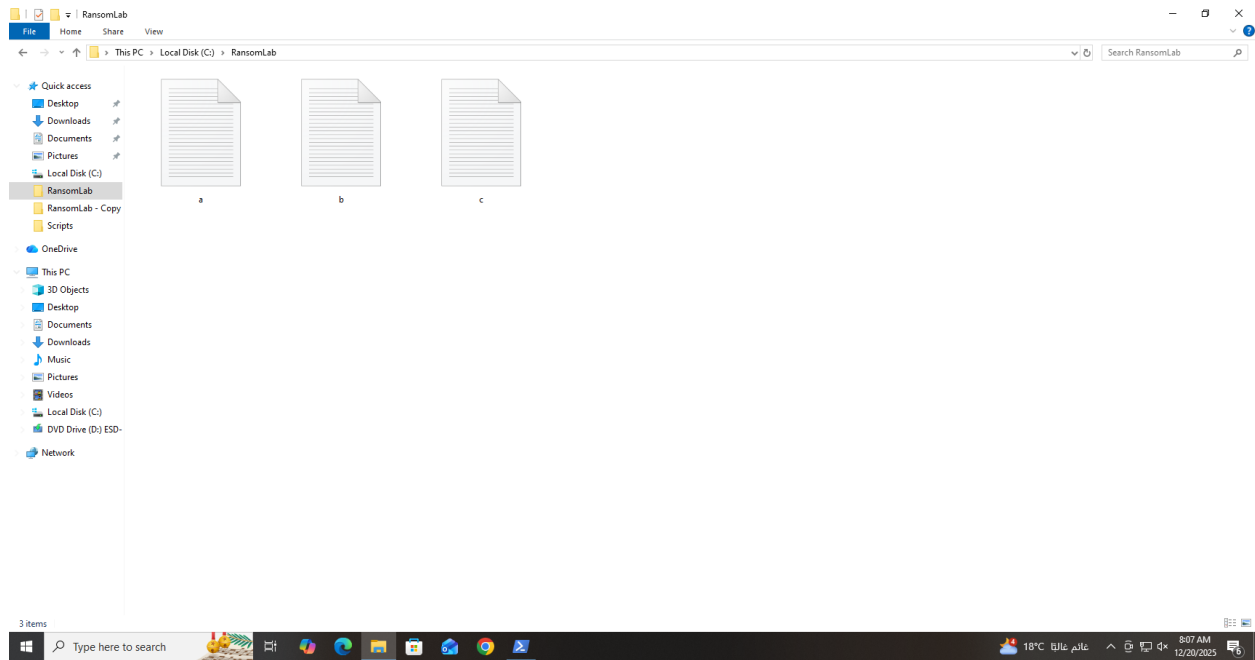
- Deployed a Windows 10 virtual machine as the victim endpoint
- Deployed an Ubuntu virtual machine hosting Elastic Stack (Elasticsearch and Kibana)
- Configured network connectivity between endpoints
- Enabled PowerShell Script Block Logging and Module Logging on the Windows 10 system
- Enrolled the Windows 10 endpoint into Elastic Fleet and verified agent connectivity

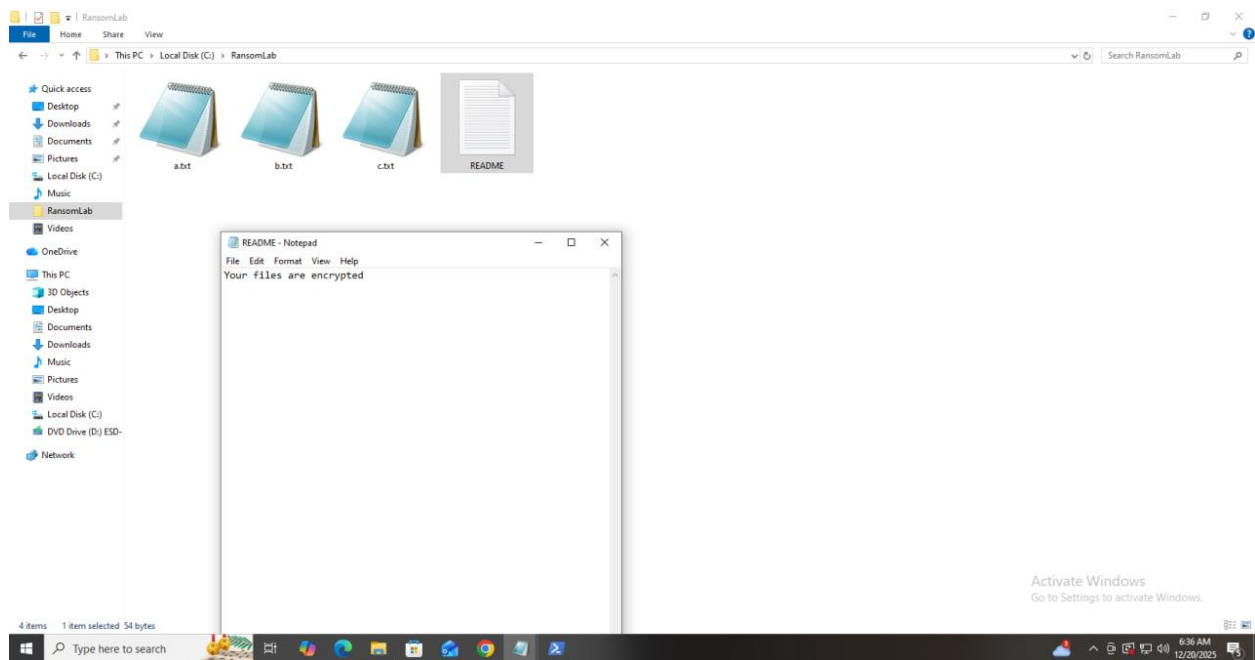
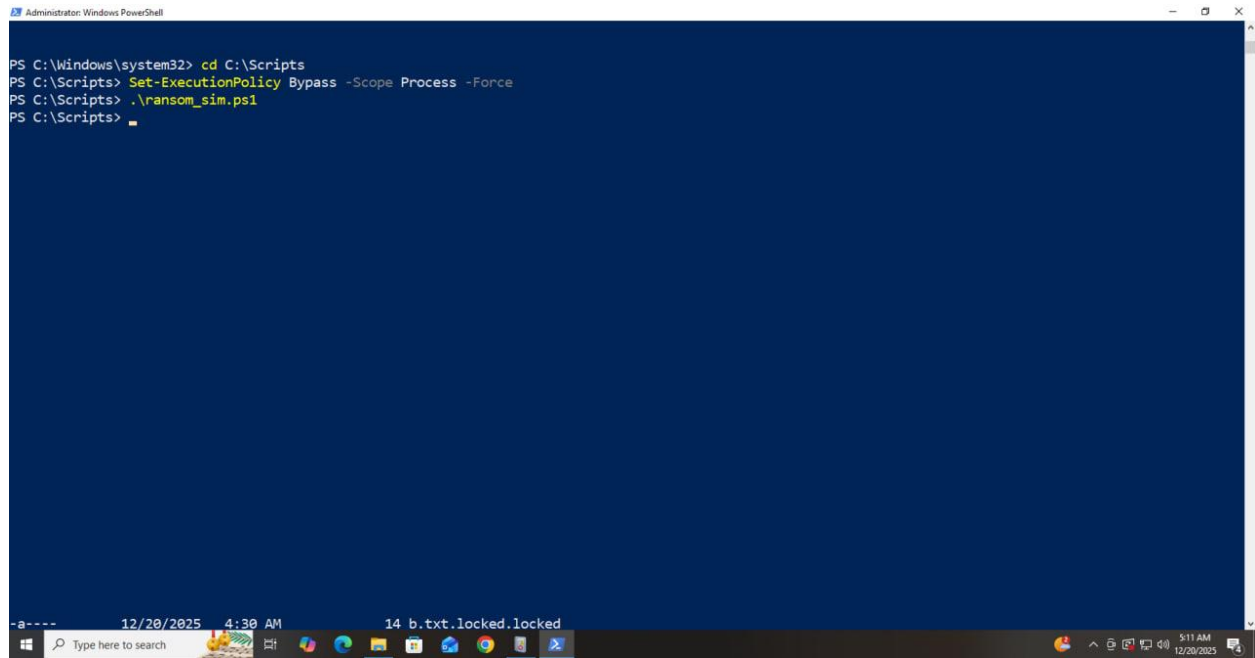
Phase 1: Execution

- Created a controlled test directory containing benign files
- Executed a PowerShell-based ransomware simulation script
- The script modified file contents, renamed files to simulate encryption, and dropped a ransom note
- The script was executed manually to simulate attacker execution.
- No real encryption or destructive activity was performed.

Observed Behavior:

- PowerShell executed file modification and rename operations
- Test files became inaccessible due to content modification
- A ransom note was created in the target directory





Phase 2: Detection & Analysis

Detect ransomware activity and analyze its behavior and impact.

Detection Sources:

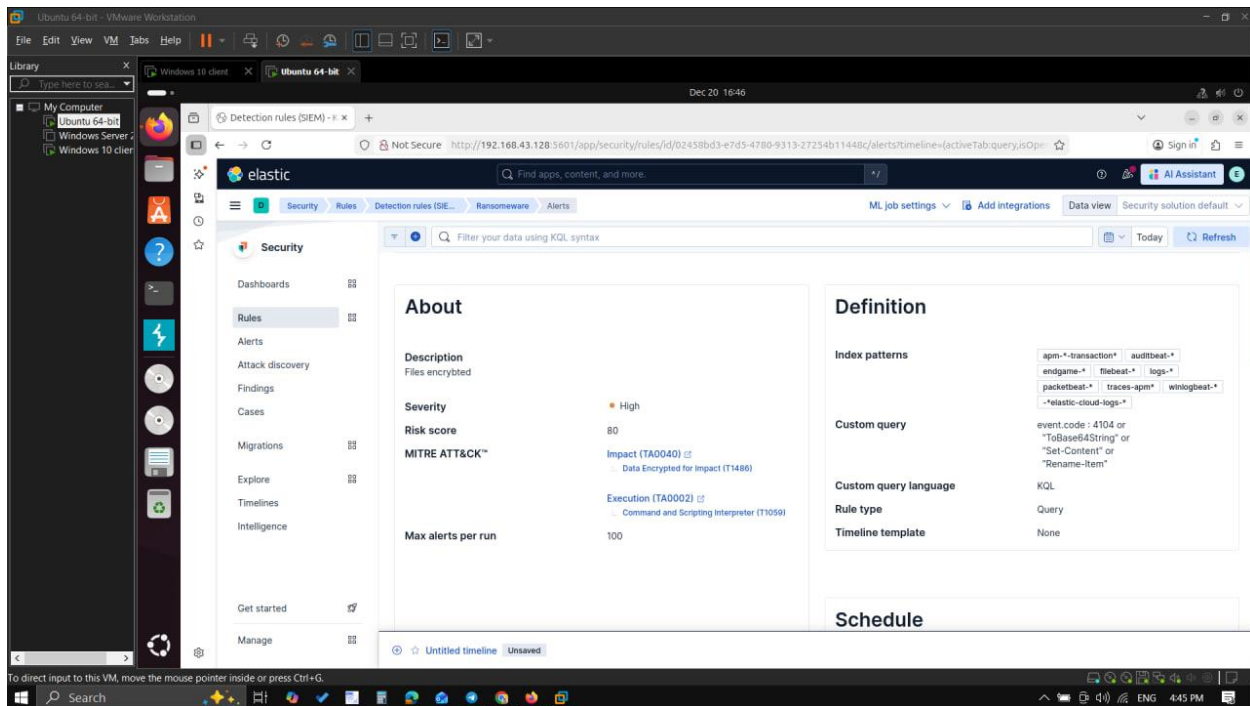
- PowerShell Script Block Logging (Event ID 4104 and 4688)
- Elastic Security detection rules

Detection Logic & Indicators:

- Execution of powershell.exe
- PowerShell commands containing ToBase64String, Set-Content, OR Rename-Item
- Creation of files with .locked extension
- Presence of a ransom note (README.txt)

Detection Rule

A detection rule was created to identify PowerShell-based attacks by monitoring suspicious PowerShell execution and script usage.



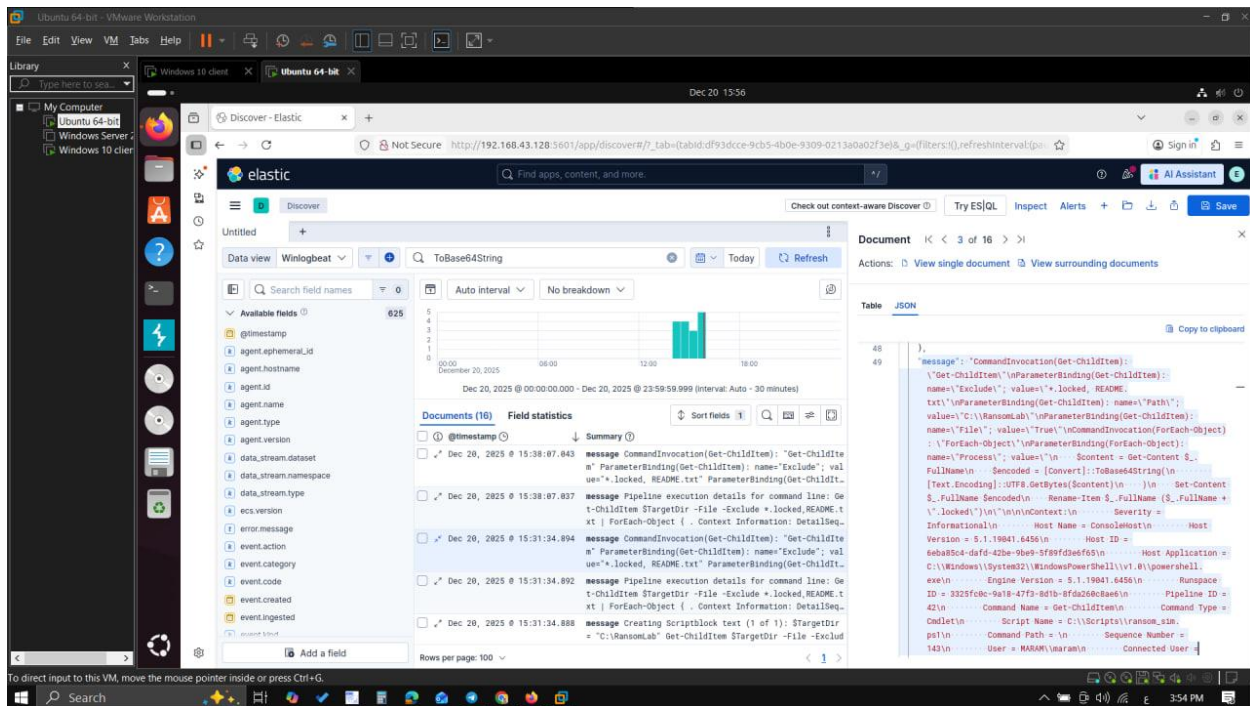
Analysis Actions:

- Reviewed PowerShell Script Block logs to identify malicious commands
- Correlated file creation and rename events with PowerShell execution
- Identified affected files and directories
- Confirmed ransomware-like impact

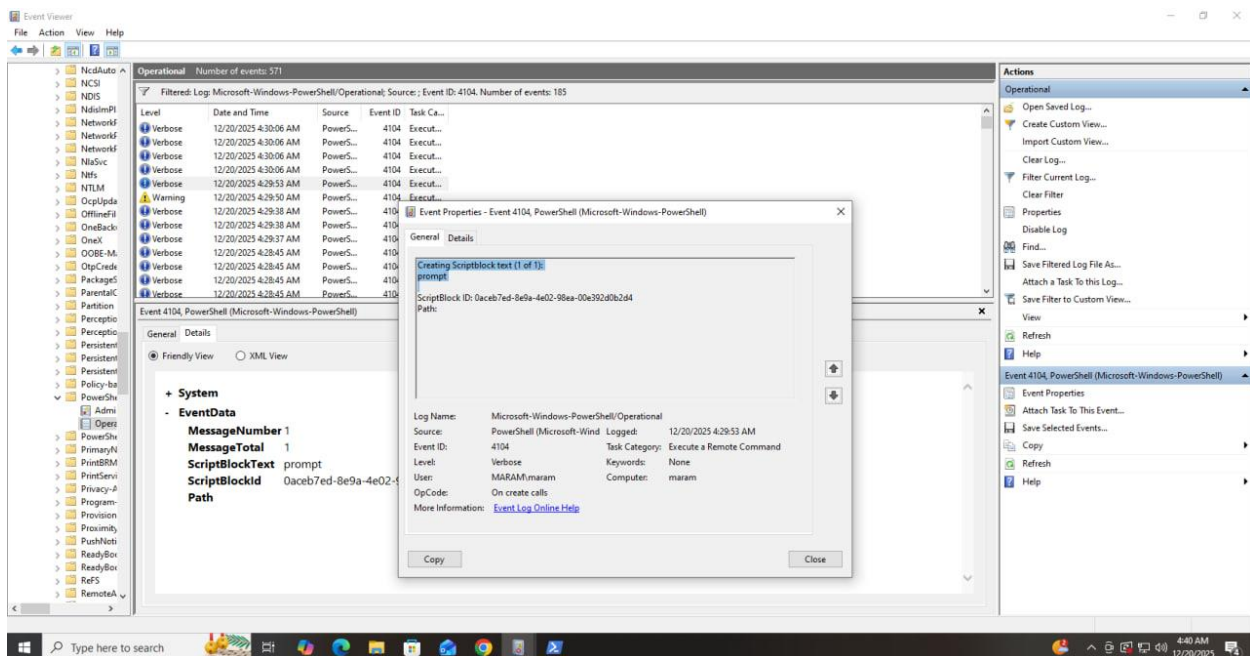
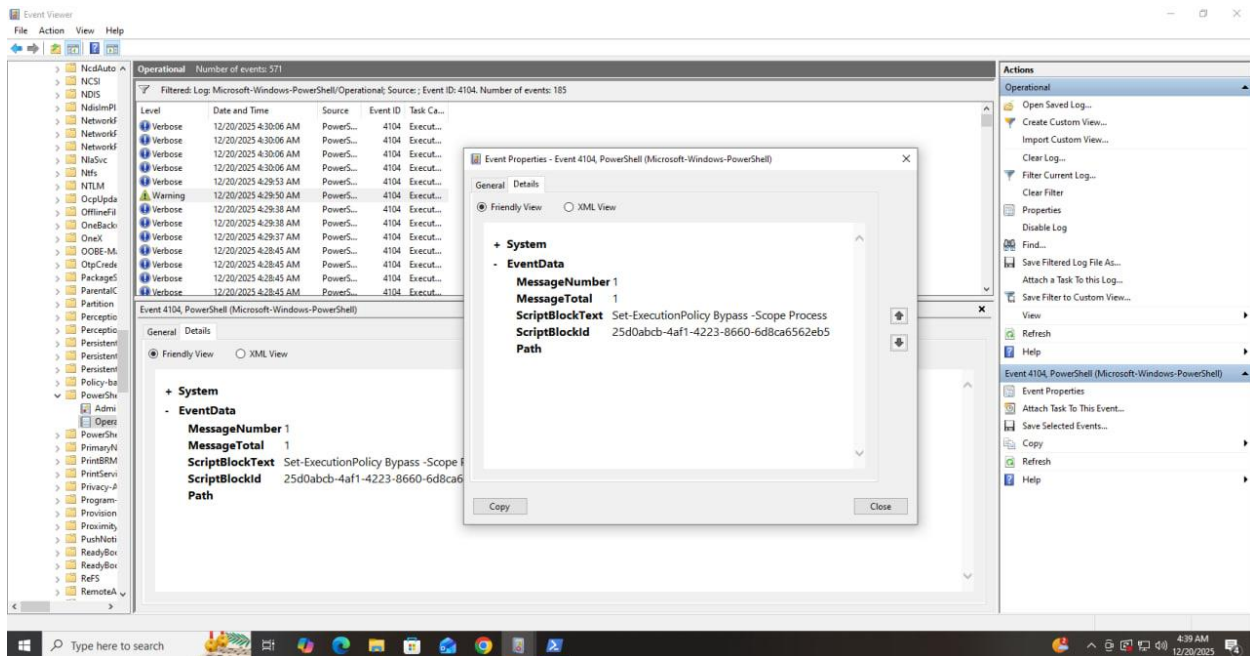
Findings:

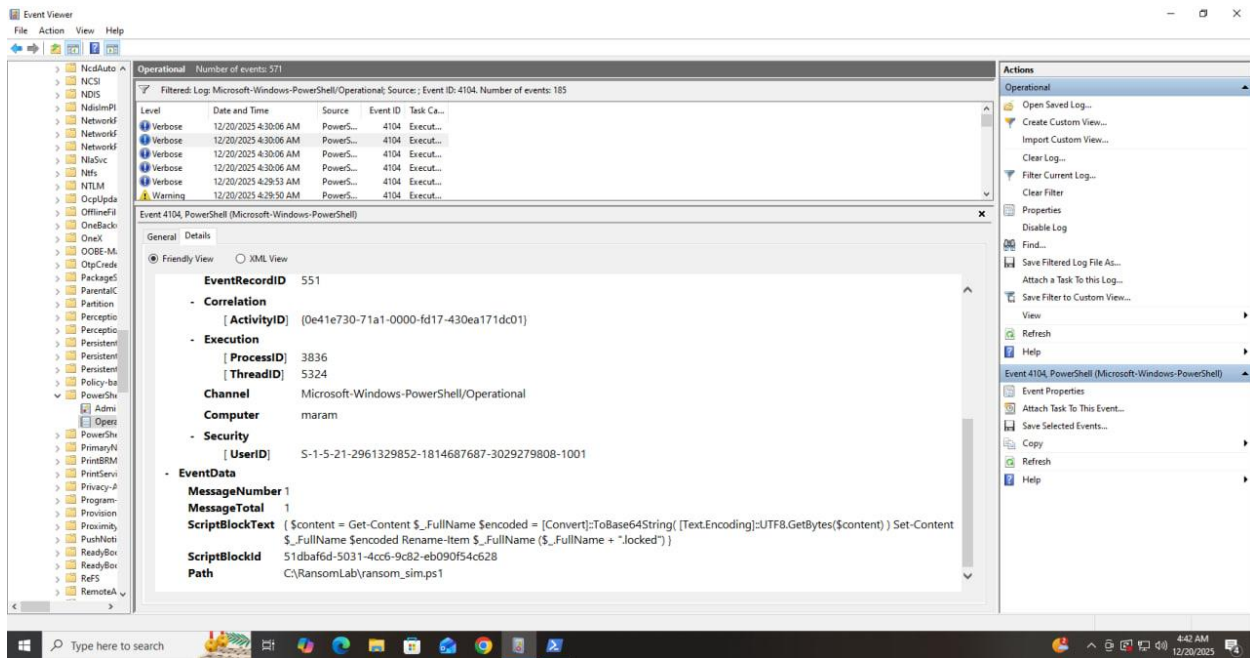
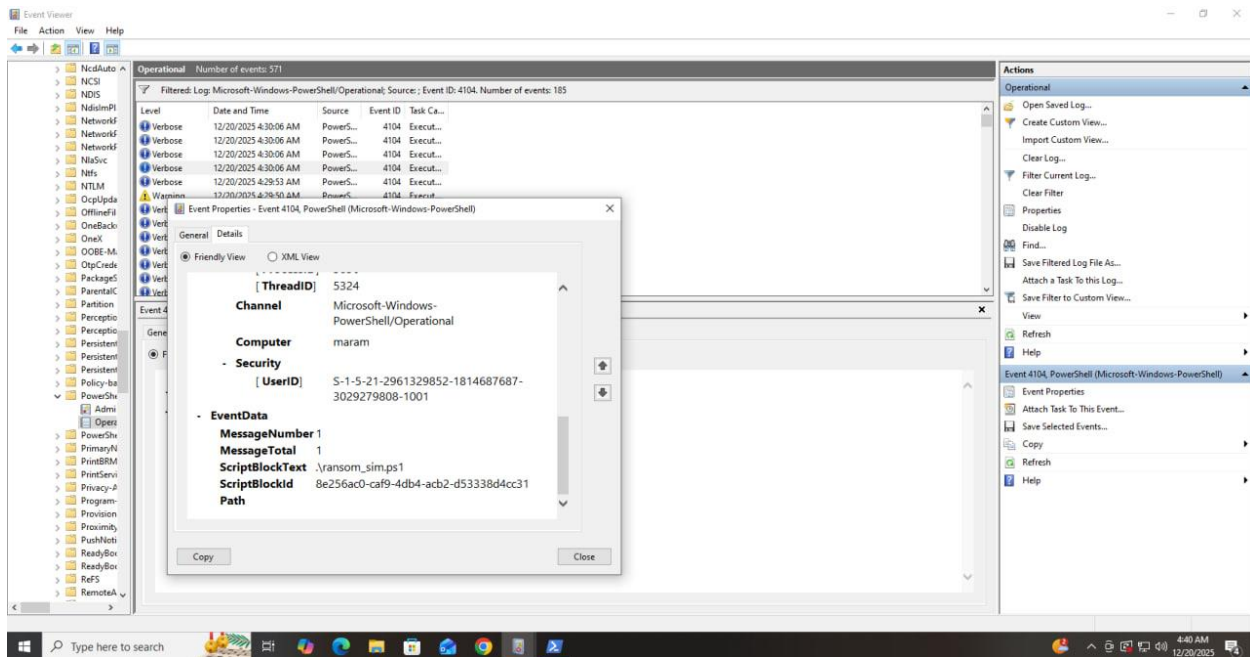
- Files were intentionally modified and renamed to simulate encryption
- Ransom note was successfully created
- No evidence of lateral movement or persistence was observed

Process Execution Evidence in (Kibana):



Process Execution Evidence in (Event Viewer): Multiple file creation and rename events were observed, consistent with ransomware behavior.





MITRE ATT&CK Mapping:

- T1059.001 – PowerShell
- T1486 – Data Encrypted for Impact

The screenshot shows the MITRE ATT&CK website in a web browser. The URL is attack.mitre.org/techniques/T1059/001/. The page title is "Command and Scripting Interpreter: PowerShell". The left sidebar lists various techniques, with "PowerShell" selected under the "Scripting Interpreter" category. The main content area describes how adversaries may abuse PowerShell commands and scripts for execution. It mentions that PowerShell is a powerful interactive command-line interface and scripting environment included in the Windows operating system. Examples include the `Start-Process` cmdlet and the `Invoke-Command` cmdlet. The page also notes that PowerShell may be used to download and run executables from the Internet. A sidebar on the right provides metadata: ID: T1059.001, Sub-technique of: T1059, Tactic: Execution, Platforms: Windows, Contributors: Mayuresh Dani, Qualys; Praetorian; Ross Brittain, Version: 1.5, Created: 09 March 2020, Last Modified: 24 October 2025. A "Version Permalink" link is also present.

The screenshot shows the MITRE ATT&CK website in a web browser. The URL is attack.mitre.org/techniques/T1486/. The page title is "Data Encrypted for Impact". The left sidebar lists various techniques, with "Data Encrypted for Impact" selected under the "Data Destruction" category. The main content area describes how adversaries may encrypt data on target systems or on large numbers of systems in a network to interrupt availability to system and network resources. It mentions that they can attempt to render stored data inaccessible by encrypting files or data on local and remote drives and withholding access to a decryption key. This may be done in order to extract monetary compensation from a victim in exchange for decryption or a decryption key (ransomware) or to render data permanently inaccessible in cases where the key is not saved or transmitted. The page also notes that in the case of ransomware, it is typical that common user files like Office documents, PDFs, images, videos, audio, text, and source code files will be encrypted (and often renamed and/or tagged with specific file markers). Adversaries may need to first employ other behaviors, such as File and Directory Permissions Modification or System Shutdown/Reboot, in order to unlock and/or gain access to manipulate these files. In some cases, adversaries may encrypt critical system files, disk partitions, and the MBR. Adversaries may also encrypt virtual machines hosted on ESXi or other hypervisors. To maximize impact on the target organization, malware designed for encrypting data may have worm-like features to propagate across a network by leveraging other attack techniques like Valid Accounts, OS Credential Dumping, and SMB/Windows Admin Shares Encryption. A sidebar on the right provides metadata: ID: T1486, Sub-techniques: No sub-techniques, Tactic: Impact, Platforms: ESXi, IaaS, Linux, Windows, macOS, Impact Type: Availability, Contributors: ExtraHop; Harshal Tupsamudre, Qualys; Mayuresh Dani, Qualys; Oleg Kolesnikov, Securonix; Travis Smith, Qualys, Version: 1.5, Created: 15 March 2019, Last Modified: 24 October 2025. A "Version Permalink" link is also present.

Phase 4: Containment

- Isolated the affected endpoint from the network
- Terminated the malicious PowerShell process
- Prevented further script execution
- Temporarily disable the affected user account if required
- **Check for:**
 - Persistence mechanisms
 - Lateral movement activity
 - Additional impacted files or systems

Phase 5: Eradication

- Deleted the ransomware simulation script
- Removed encrypted test files and ransom note
- Verified no persistence mechanisms remained

Phase 6: Recovery

- Restored files from backup (assumed for simulation)
- Validated system integrity
- Reconnected the endpoint to the network
- Reset credentials for impacted accounts

Phase 7: Lessons Learned

- PowerShell Script Block Logging provided high-fidelity visibility
- Sysmon enhanced detection of file-level ransomware behavior
- Behavioral detection was effective for ransomware activity

Recommendations:

- Enable PowerShell Script Block Logging across all endpoints
- Monitor bulk file modification and rename behavior
- Restrict PowerShell usage using security controls
- Improve user awareness against script-based attacks
- Tune detection rules to reduce false positives

